

YS Admin (CMS) — Comprehensive Architecture, Operations & Security Manual

System Version: 2.4.0-Hardened

Environment: Next.js 16 (App Router) / React 19 / Prisma 7 / PostgreSQL (Supabase) / NextAuth.js

Author: Subash M.R

Classification: Confidential — Proprietary Internal Engineering & Operational Architecture Manual

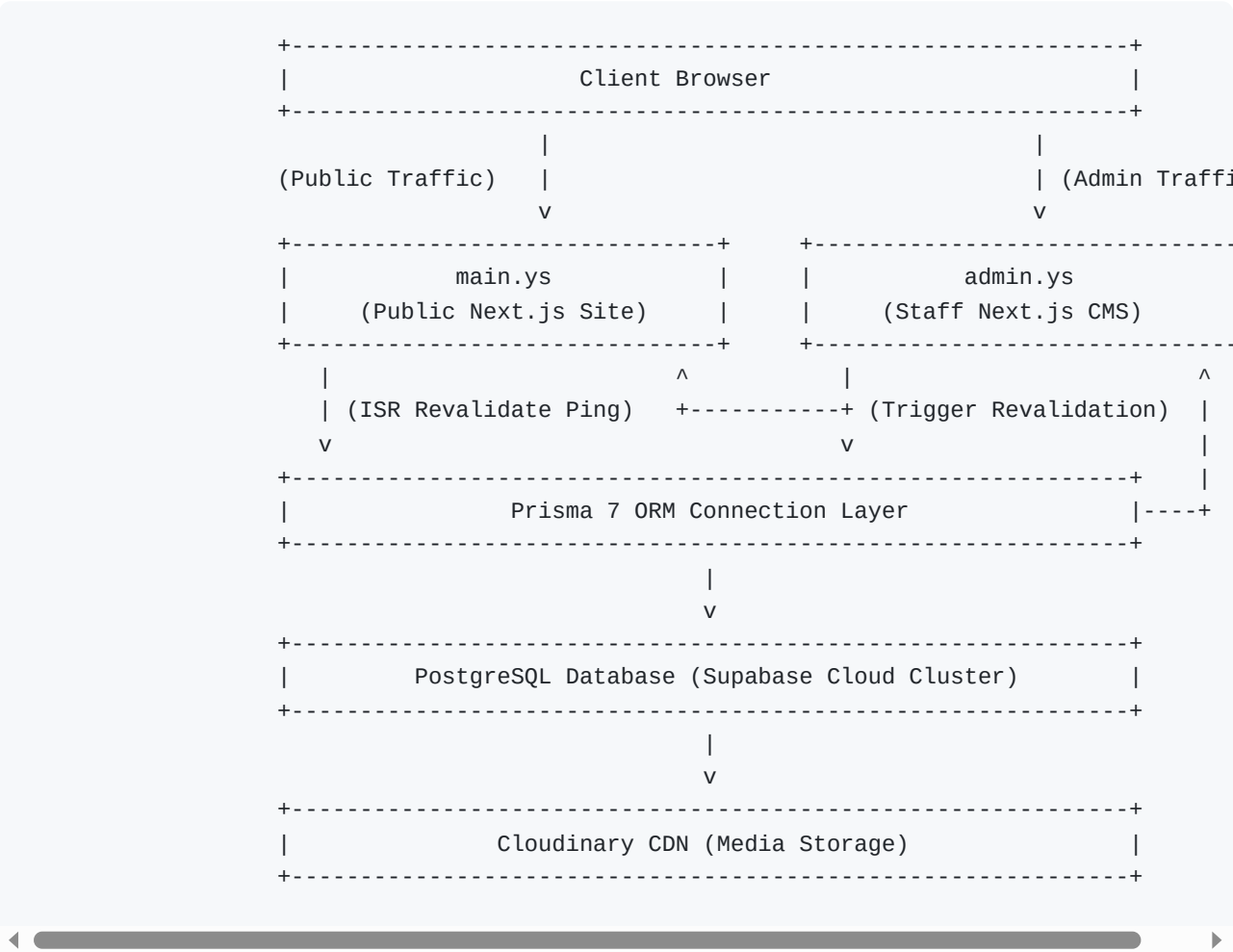
Table of Contents

- 1. [System Overview & Architecture Topology](#)
- 2. [Role-Based Access Control \(RBAC\) Matrix](#)
- 3. [PART 1: Operational User Manual \(Action-Driven UI & System Workflows\)](#)
 - [Module 1: Authentication & Next.js 16 Proxy Lifecycle](#)
 - [Module 2: Dashboard Overview & Telemetry](#)
 - [Module 3: Webpages Management & SEO Engine \(SEO Quick Edit Modal\)](#)
 - [Module 4: Live Schema-Driven Page Editor](#)
 - [Module 5: Blog Publishing Engine & Quick Edit Modal](#)
 - [Module 6: Comments & Discussions Moderation](#)
 - [Module 7: Global Header Navigation Manager](#)
 - [Module 8: Global Footer & Legal Manager](#)
 - [Module 9: Cloudinary Media Library](#)
 - [Module 10: Staff & User Management](#)
 - [Module 11: Customer Inquiries & Form Submissions Inbox](#)
 - [Module 12: Redirects & Canonical Routing](#)
 - [Module 13: Staff Profile & Account Settings](#)
- 4. [PART 2: Deep-Dive Security & Hardening Architecture](#)
 - [2.1 Cryptographic Password Storage \(Bcrypt 12 Salt Rounds\)](#)
 - [2.2 Next.js 16 Proxy Architecture & Sliding-Window Rate Limiting](#)
 - [2.3 Anti-Bot Honeypot Defense Architecture](#)
 - [2.4 Identity Spoofing Mitigation \(Authoritative Badging\)](#)
 - [2.5 Object-Level Authorization & RBAC Enforcement](#)
 - [2.6 Timing-Safe ISR Cache Purging](#)
 - [2.7 HTTP Hardening & Network Transport Security](#)

- 5. [PART 3: Architectural Roadmap & Future RFCs](#)
 - [RFC 1: Real-Time Team Presence & Collaborative Page Locking](#)
 - [RFC 2: Decoupled Python SEO Audit & Crawling Engine](#)
 - [RFC 3: Enterprise Immutable Audit Logging](#)

1. System Overview & Architecture Topology

The **YS Admin CMS** is a headless content and configuration engine powering the public web client (`main.js`). The system is architected around decoupling content entry from public consumption to guarantee high performance, security isolation, and instantaneous page delivery.



Key Technical Characteristics:

1. **Frontend CMS Engine:** Next.js 16 with React 19 compiler optimization and Server Actions.
2. **Database & ORM:** PostgreSQL running on Supabase, abstracted via Prisma 7 with pooled direct connections.

- 3. **Media CDN:** Cloudinary unsigned presets for client-side direct uploads, bypassing application memory overhead.
- 4. **Cache Invalidation:** On-demand Incremental Static Regeneration (ISR) using HMAC-secured timing-safe revalidation webhooks.

2. Role-Based Access Control (RBAC) Matrix

The system enforces strict multi-tier role authorization. Privileges are verified at both the modern Next.js 16 Proxy layer (`src/proxy.ts` , which supersedes legacy `middleware.ts`) and individual API route handlers.

Capability / Resource	ADMIN Role	EDITOR Role	Unauthenticated Visitor
Access CMS Dashboard	Granted	Granted	Denied (Redirect to <code>/login</code> / 401)
Edit Page Content & SEO Metadata	Granted	Granted	Denied (401)
Move Pages / Blogs to Trash	Granted	Granted (All blogs)	Denied (401)
Permanently Purge Trashed Pages	Granted	Denied (403)	Denied (401)
Create & Edit All Blog Posts	Granted	Granted (Universal)	Denied (401)
Permanently Purge Trashed Blogs	Granted	Denied (403)	Denied (401)
Cloudinary Media Upload	Granted	Granted	Denied (401)
Permanently Destroy Media	Granted	Denied (403)	Denied (401)
Create Staff Users & Set Roles	Granted	Denied (403)	Denied (401)
Moderate & Reply to Comments	Granted (<code>isAdmin: true</code>)	Denied (Hidden from Sidebar)	Denied (401)

Capability / Resource	ADMIN Role	EDITOR Role	Unauthenticated Visitor
Global Header / Footer Config	Granted	Granted	Denied (401)
Manage Personal Account Profile	Granted	Granted	Denied (401)

PART 1: Operational User Manual

(Action-Driven UI & System Workflows)

This section documents every administrative capability in the exact format requested by engineering leads: **Action -> UI Trigger -> System Execution -> Database Mutations -> Cache Effects -> Edge Case Failures.**

Module 1: Authentication & Next.js 16 Proxy Lifecycle

- **Path:** `/login`
- **Target Audience:** All staff members (`ADMIN` and `EDITOR`).

Action 1.1: Staff Sign-In

- **Trigger:** User fills in Email + Password and clicks "**Sign In**".
- **UI Feedback:** Sign In button enters loading state (`spinner` active, inputs disabled).
- **Under The Hood:**
 - i. Payload intercepted by Next.js 16 Proxy (`src/proxy.ts`). Sliding-window rate limiter verifies client IP has not exceeded 10 attempts in 5 minutes.
 - ii. NextAuth `CredentialsProvider` queries PostgreSQL `User` table for matching normalized email.
 - iii. `bcrypt.compare(password, user.password)` validates password hash against 12-round salt.
 - iv. Upon success, `lastLogin` timestamp in database updates to `new Date()` .
 - v. An HTTP-only encrypted JWT session cookie is issued with a 7-day expiration.
- **Database Mutation:**

```
UPDATE "User" SET "lastLogin" = NOW() WHERE "id" = :userId;
```

- **Failure Modes:**
 - *Wrong Password / Unknown Email:* UI displays red error banner: "Incorrect email or password".
 - *Rate Limit Triggered (10 fails in 5m):* Request returns `HTTP 429` . UI displays warning: "Too many failed login attempts. Please try again after 5 minutes."

Action 1.2: Explicit Staff Logout

- **Trigger:** User clicks Profile Avatar (bottom left) -> "Log out".
- **UI Feedback:** Immediate redirect to `/login` with clean query params.
- **Under The Hood:** NextAuth invalidates the JWT session cookie in the browser. Subsequent page requests are intercepted by Next.js 16 Proxy (`src/proxy.ts`) and redirected to `/login` .

Module 2: Dashboard Overview & Telemetry

- **Path:** `/`
- **Target Audience:** All staff members.

Action 2.1: Telemetry Data Aggregation

- **Trigger:** Automatic upon mounting `/` .
- **UI Feedback:** Metric cards (Total Pages, Published Blogs, Total Comments, Media Storage) render skeleton loaders and transition to live counts.
- **Under The Hood:** Dispatches `GET /api/dashboard/stats` running optimized `prisma.$transaction` aggregate counts across tables.
- **Failure Modes:** If database is unreachable, metrics render default zero state with a warning toast.

Module 3: Webpages Management & SEO Engine

- **Path:** `/webpages`
- **Target Audience:** Content Managers & Site Administrators.

Action 3.1: Schema-Driven Webpage Catalog & Lifecycle Management

- **Overview:** In accordance with the system's strict architectural directives, website pages are defined by developer code schemas (`homepage-ui-schema.ts` , `careers-ui-schema.ts` , `contact-ui-schema.ts` , `services-ui-schema.ts`). Content editors manage text payloads, media, SEO metadata, and publish statuses without altering raw layout structures.
- **UI Controls:**

- **Global Header / Footer Quick Access:** Dedicated top cards directing to `/header` and `/footer`.
- **Live Site Shortcut:** "View Site" header button opening the frontend client (`main.js`).
- **4 Status Metric Filter Tabs:** Interactively filters pages by **All** (`totalCount`), **Published** (`publishedCount`), **Drafts** (`draftCount`), and **Trash** (`trashedCount`).
- **Search Bar:** Real-time filtering by page title or URL slug.

Action 3.2: SEO Quick Edit Modal (`SeoQuickEditModal.tsx`)

- **Trigger:** Click `...` menu on any webpage row -> Click **"Edit SEO"**.
- **UI Feedback:** Modal opens displaying comprehensive search optimization inputs:
 - **Page Title & URL Slug:** Core route identity.
 - **Search Engine Meta Title:** Input with live character count recommendation (recommended: 50–60 chars).
 - **Search Engine Meta Description:** Textarea with live character counter (recommended: 150–160 chars).
 - **Focus Keyword:** Primary keyword for target ranking.
 - **OpenGraph Social Share Image:** Dropzone with direct client-side Cloudinary unsigned upload (`ImageUploadBlock`).
 - **OpenGraph Title & Description:** Overrides for Facebook/LinkedIn/Twitter previews.
 - **Canonical URL:** Custom canonical link tag to consolidate duplicate URL equity.
 - **Structured Data (JSON-LD):** Raw JSON textarea with syntax error validation for Google rich snippets.
 - **Search Engine Indexing Switch:** Toggle for `noIndex` (adds `noindex, nofollow` robots tag).
- **Under The Hood:**
 - Validates form data against Zod schema `seoQuickEditSchema`.
 - Dispatches `PUT /api/webpages/[id]/seo`.
 - Server upserts the associated `SeoMeta` 1-to-1 record attached to the `Page`.
 - Triggers `revalidateFrontendPath(page.slug)` on `main.js` to purge edge CDN caches.
- **Database Mutation:**

```
INSERT INTO "SeoMeta" (
  "id", "metaTitle", "metaDesc", "focusKeyword", "ogImage",
  "ogTitle", "ogDesc", "canonicalUrl", "structuredData", "noIndex", "pageId"
) VALUES (
  cuid(), :metaTitle, :metaDesc, :focusKeyword, :ogImage,
  :ogTitle, :ogDesc, :canonicalUrl, :structuredDataJson, :noIndex, :pageId
)
ON CONFLICT ("pageId") DO UPDATE SET
  "metaTitle" = :metaTitle,
  "metaDesc" = :metaDesc,
  "focusKeyword" = :focusKeyword,
```

```
"ogImage" = :ogImage,
"ogTitle" = :ogTitle,
"ogDesc" = :ogDesc,
"canonicalUrl" = :canonicalUrl,
"structuralData" = :structuralDataJson,
"noIndex" = :noIndex;
```

- **Live Site Effect:** Search crawlers and social scrapers (WhatsApp, Twitter/X, Slack, Googlebot) immediately receive the refreshed OpenGraph image and JSON-LD schema without deploying code.

Action 3.3: Two-Step Soft-Delete & Permanent Trash Purge

- **Step 1 (Move to Trash):** Click `...` menu on page row -> Click **"Move to Trash"**.
 - *Database Mutation:* Updates `"Page" SET "isTrashed" = true, "status" = 'draft' .`
 - *UI Feedback:* Item moves from Active list to the "Trash" tab.
- **Step 2 (Permanent Deletion — Admin Only):** Switch to "Trash" tab -> Click `...` -> Click **"Permanently Delete"** -> Confirm prompt.
 - *Under The Hood:* `DELETE /api/pages/[id]` checks `session.user.role === "ADMIN" .`
 - *Safety Assertion:* If an API request attempts to permanently delete an active page without it being trashed first (`!page.isTrashed`), the server rejects with `HTTP 400 Bad Request: Page must be moved to trash before permanent deletion .`
 - *Database Mutation:* Deletes the page record (`DELETE FROM "Page" WHERE "id" = :id`).
 - *Live Site Effect:** Sends ISR cache purge webhook to `main.js` . Visiting `main.js/[slug]` yields a clean `404 Not Found` .

Module 4: Live Schema-Driven Page Editor

- **Path:** `/editor/[id]`
- **Target Audience:** Content Editors & Administrators.

Action 4.1: Schema-Driven Accordion Sections (`SchemaEditor.tsx`)

- **Overview:** Instead of unconstrained visual dragging that risks breaking mobile layout responsiveness, the editor renders developer-approved structural schemas (`homepage-ui-schema.ts` , `careers-ui-schema.ts` , etc.) inside collapsible accordions.
- **UI Feedback:** Sections (Hero, Features, Testimonials, CTA, FAQ) feature smooth expand/collapse toggles, "Expand All", and "Collapse All" controls.
- **Input Fields:** Form controls automatically render typed inputs (text, textareas, image upload widgets with Cloudinary integration, array item repeaters) strictly matching the underlying page JSON schema.

Action 4.2: Real-Time Debounced Live Preview Synchronization

- **Trigger:** Editor types text or selects images inside any form field.
- **Under The Hood:**
 - i. Form state subscribes to changes via React Hook Form `watch()` .
 - ii. A 300ms debouncing hook (`sendToPreview`) transmits the updated section payload to the preview iframe using `postMessage` .
 - iii. The iframe (`main.js`) listens for `PREVIEW_UPDATE` messages and re-renders components instantly without triggering page reloads.

Action 4.3: Save Draft & Publish Page

- **Trigger:** Click "**Save Draft**" or "**Publish Changes**" in the top navbar.
- **Validation Enforcement:** Before saving, `SchemaEditor` executes strict Zod schema validation (`schemaEditorRef.current.validate()`). If any required field or structure violates Zod rules, submission halts and the invalid input highlights with an error message.
- **UI Feedback:** Button states update smoothly (`Publishing...` -> `Page published successfully`).
- **Database Mutation:**

```
UPDATE "Page"
SET "content" = :jsonPayload, "status" = 'published', "updatedAt" = NOW()
WHERE "id" = :pageId;
```

- **Live Site Effect:** Dispatches authenticated HTTP POST to `main.js/api/revalidate` . Next.js on-demand ISR regenerates static HTML for that slug; public visitors immediately see the updated content.

Module 5: Blog Publishing Engine & Quick Edit Modal

- **Path:** `/blogs` & `/blogs/[id]`
- **Target Audience:** Authors, Copywriters, and Administrators.

Action 5.1: Create Draft Blog Post

- **Trigger:** Click "**Create Post**" -> Enter title, summary, select tags.
- **Database Mutation:** New `Blog` record created with status `draft` and `authorId = session.user.id` .

Action 5.2: Direct Cloudinary Unsigned Image Upload

- **Trigger:** User drops featured image into upload box.
- **UI Feedback:** Upload progress percentage bar (0% -> 100%) renders inside the drop zone.

- **Under The Hood:**
 - i. Browser bypasses Next.js server entirely and posts directly to Cloudinary API using `NEXT_PUBLIC_CLOUDINARY_UPLOAD_PRESET`.
 - ii. Cloudinary returns secure HTTPS CDN URL.
 - iii. Image URL saved in post state. Zero server memory or bandwidth consumed on CMS backend.

Action 5.3: Rich-Text Article Authoring (TipTap Engine)

- **Trigger:** Click into the body text area in `/blogs/[id]`.
- **UI Feedback:** Full rich-text WYSIWYG capabilities powered by `@tiptap/react` and `@tiptap/starter-kit`. Includes floating bubble menu, headings, blockquotes, unordered/ordered lists, underline, inline links, embedded images, and data tables (`@tiptap/extension-table`).

Action 5.4: Publish & Draft Toggle

- **Trigger:** Click "Publish" switch or button.
- **Database Mutation:** Status becomes `published`, `publishedAt = NOW()`.
- **Live Site Effect:** Calls `revalidateFrontendPath("/blogs")` (updating archive) and `revalidateFrontendPath("/blogs/[slug]")` (updating single article).

Action 5.5: Blog Quick Edit Modal (`BlogQuickEditModal.tsx`)

- **Trigger:** Click `...` menu on any blog row -> Click "Quick Edit".
- **UI Feedback:** Modal opens allowing instant metadata changes without loading the heavy TipTap editor:
 - **Blog Title & URL Slug**
 - **Author Attribution Select** (Admin can reassign post author)
 - **Tags & Categories**
 - **Allow Comments Switch**
 - **Complete Search Engine SEO Metadata:** Meta Title, Meta Description, Focus Keyword, Canonical URL, and `noIndex` toggle.
- **Under The Hood:** Dispatches `PUT /api/blogs/[id]/seo` validating against `blogQuickEditSchema` and upserting the associated `SeoMeta` record.

Action 5.6: Universal Blog Editing & Admin-Only Permanent Trash Purge

- **Universal Editing Access:** Content editors have full permissions to edit, update SEO metadata for, and publish or unpublish all blog posts across the platform regardless of who originally authored them.

- **Two-Step Trash Lifecycle:** Blogs cannot be deleted directly while active. Any editor or admin can move any post to Draft or to Trash (`isTrashed: true`).
 - **Admin-Only Permanent Deletion:** Editors cannot permanently delete any blog post, even if they authored it. The permanent purge action is hidden from the editor UI, and backend API requests to `DELETE /api/blogs/[id]` strictly assert `session.user.role === "ADMIN"` (rejecting non-admin requests with `HTTP 403 Forbidden`).
-

Module 6: Comments & Discussions Moderation

- **Path:** `/comments`
- **Target Audience:** Administrators Only (Hidden from sidebar and UI for Editors; route and API access strictly enforce `session.user.role === "ADMIN"`).

Action 6.1: Approve / Reject / Trash Comment

- **Trigger:** Click green **"Approve"** checkmark, amber **"Hold"** icon, or red **"Trash"** icon on incoming comment.
- **Database Mutation:** Updates boolean columns `isApproved: true/false` or `isTrashed: true` via `PATCH /api/comments/[id]` .
- **Live Site Effect:** Revalidates the specific blog post URL so visitors see approved comments immediately.

Action 6.2: Post Official Staff Reply

- **Trigger:** Click **"Reply"** on any comment -> type response -> Click **"Send Reply"**.
- **UI Feedback:** Reply is immediately appended to thread with an official golden **"YS Staff / Admin"** badge.
- **Under The Hood:** Server forces `isAdmin: true` regardless of what client payload sends:

```
await prisma.comment.create({
  data: {
    blogId,
    name: `${session.user.name || "YS Team"} (Admin)`,
    email: session.user.email || "admin@ysinnovations.com",
    content: cleanContent,
    isApproved: true, // Auto-approved
    isTrashed: false,
    isAdmin: true,    // Authoritative assignment
    parentId: commentId,
  }
});
```

Module 7: Global Header Navigation Manager

- **Path:** `/header`
- **Target Audience:** Administrators & Editors.

Action 7.1: Drag-and-Drop Menu Reordering (`@dnd-kit`)

- **Trigger:** Grabbing the drag handle of any navigation link in `MenuBuilderBlock.tsx` and reordering links.
- **UI Feedback:** Real-time smooth drag animation powered by `@dnd-kit/core` , `@dnd-kit/sortable` , and `@dnd-kit/utilities` .

Action 7.2: Update Navigation Items & Call-To-Action

- **Trigger:** Add new navigation link (Label: *"Careers"*, URL: `/careers` , Target: `_self`) or update CTA button -> Click **"Save Header"**.
- **Database Mutation:** Server Action `saveHeaderData` upserts into `Header` table (`id: "global"`):

```
INSERT INTO "Header" ("id", "content", "updatedAt")
VALUES ('global', :jsonPayload, NOW())
ON CONFLICT ("id") DO UPDATE SET "content" = :jsonPayload, "updatedAt" = NOW();
```

- **Live Site Effect:** Dispatches `revalidateFrontendPath("/", "layout")` across `main.js` . Every page displays the updated navigation bar instantly without requiring site redeployment.

Module 8: Global Footer & Legal Manager

- **Path:** `/footer`
- **Target Audience:** Administrators & Editors.

Action 8.1: Update Footer Columns, Newsletter & Contact Info

- **Trigger:** Modify address, email (`contact@ysinnovations.com`), social links, or policy links -> Click **"Save Footer"**.
- **Database Mutation:** Upserts into `Footer` table (`id: "global"`).
- **Live Site Effect:** Global layout cache invalidation propagates updated footer instantly.

Module 9: Cloudinary Media Library

- **Path:** `/media`
- **Target Audience:** All staff (Browse/Upload); Admins (Delete).

Action 9.1: Copy Image CDN URL

- **Trigger:** Click on any uploaded asset card -> click **"Copy URL"**.
- **UI Feedback:** Toast confirms: *"URL copied to clipboard"*.

Action 9.2: Permanent Media Destruction (Admin Only)

- **Trigger:** Click trash icon on image -> confirm in modal.
 - **Under The Hood:**
 - i. API checks `session.user.role === "ADMIN"`.
 - ii. Node.js backend calls Cloudinary SDK `cloudinary.v2.uploader.destroy(publicId)`.
 - iii. Image is permanently purged from Cloudinary CDN edge servers.
 - **Failure Modes:** Non-admin roles receive `HTTP 403 Forbidden: Only administrators can destroy media assets`.
-

Module 10: Staff & User Management

- **Path:** `/users`
- **Target Audience:** Strictly `ADMIN` role.

Action 10.1: Onboard New Staff Member

- **Trigger:** Click **"+ Add User"** -> Enter Name, Email, Password, Role (`ADMIN` or `EDITOR`) -> Click **"Create Account"**.
 - **UI Feedback:** Modal closes, new user card appears in list with green status dot.
 - **Under The Hood:**
 - i. Server validates password complexity: ≥ 8 characters, must contain at least 1 letter and 1 number.
 - ii. Server generates a cryptographically secure salt with **12 rounds** using `bcryptjs`.
 - iii. Hashes plaintext password and saves new record.
 - **Failure Modes:**
 - If password does not satisfy complexity: Returns `400 Bad Request` (*"Password must contain both letters and numbers"*).
 - If email exists: Returns `400 Bad Request` (*"User with this email already exists"*).
-

Module 11: Customer Inquiries & Form Submissions Inbox

- **Path:** `/notifications`
- **Target Audience:** Support Team, Sales, and Administrators.

Action 11.1: Lead Triage, Copy-to-Clipboard & Drawer Inspection

- **Overview:** The notification center functions as the centralized intake repository for public inquiries submitted through `main.js` landing pages and contact forms (`FormSubmission` model).
 - **UI Controls & Workflow:**
 - **Interactive Filter Tabs:** Quickly filters submissions across **All** (`totalCount`), **Unread** (`unreadCount`), and **Trash** (`trashedCount`).
 - **Real-time Search:** Filters records by visitor name, email, phone number, message text, or source page URL.
 - **One-Click Clipboard Copying:** Instant copy buttons for contact email and phone numbers with animated confirmation toasts.
 - **Detailed Inspection Drawer:** Selecting any inquiry opens a slide-over panel displaying raw message payloads, submission timestamp, client IP address, user-agent details, and the referring source URL.
 - **Read State Toggling:** Toggle between unread (bold highlight with indicator dot) and read states.
 - **Two-Step Trash Deletion:** Inquiries can be moved to Trash, restored, or permanently deleted.
-

Module 12: Redirects & Canonical Routing

- **Path:** `/redirections` (Alias: `/redirection`)
- **Target Audience:** SEO Managers & Administrators.

Action 12.1: Add 301 / 302 Permanent or Temporary Redirects

- **Trigger:** Enter Source URL (e.g. `/old-contact`) -> Destination URL (`/contact`) -> Status code `301` or `302` -> Click "Add Redirect".
 - **Loop & Chain Prevention Engine:**
 - Validates URL formats using Zod schema `createRedirectionSchema` .
 - **Self-Loop Blocker:** Rejects requests where `sourceUrl === destinationUrl` .
 - **Circular Chain Blocker:** Prevents configuring a destination that is already active as a source, or a source that is already active as a destination (e.g. `/a -> /b -> /a`).
 - **Live Site Effect:** Modern Next.js 16 Proxy in `main.js` (`src/proxy.ts`) intercepts incoming paths and executes immediate `HTTP 301 Moved Permanently` or `HTTP 302 Found` , preserving search rank equity.
-

Module 13: Staff Profile & Account Settings

- **Path:** `/account`
- **Target Audience:** All authenticated staff members.

Action 13.1: Profile Customization

- **Trigger:** Navigate to `/account` -> Update Display Name, Public Author Role, Bio Description, or upload Profile Picture -> Click "**Save Changes**".
- **Under The Hood:**
 - i. Profile picture uploads directly to Cloudinary CDN via `ImageUploadBlock`.
 - ii. Dispatches `PUT /api/account` updating the `user` record for `session.user.id`.
 - iii. Changes reflect across blog author cards and comment replies.

Action 13.2: Secure Password Rotation

- **Trigger:** In `/account`, enter Current Password, New Password (min 8 chars, letter + number), and Confirm Password -> Click "**Update Password**".
- **Under The Hood:**
 - i. Validates current password using `bcrypt.compare`.
 - ii. Re-hashes the new password with **12 salt rounds** using `bcryptjs`.
 - iii. Updates password hash in PostgreSQL.

PART 2: Deep-Dive Security & Hardening Architecture

This section details the defense-in-depth security mitigations implemented across `admin.js` and `main.js`.

2.1 Cryptographic Password Storage (Bcrypt 12 Salt Rounds)

The Threat:

In the event of a database compromise (SQL injection or leaked database dump), fast hashing algorithms (like MD5 or SHA-256) allow attackers to compute billions of guesses per second using commercial GPUs and rainbow tables.

The Implementation:

In `admin.js/src/app/api/users/route.ts`:

```
const hashedPassword = await bcrypt.hash(password, 12);
```

Why 12 Salt Rounds?

- **Cost Factor:** Bcrypt uses an exponential cost function (2^{cost}). At 12 rounds, it performs $2^{12} = 4,096$ iterations.
- **Hardware Resistance:** 12 rounds takes approximately 250ms to 350ms of CPU compute per hash on modern server processors.
- **Attack Feasibility:** For a single user login, 300ms is imperceptible. But for an attacker attempting to crack a leaked hash, calculating 1 billion guesses would take over **9.5 years** on high-end hardware.
- **Automatic Salting:** Bcrypt generates a cryptographically unique 128-bit salt for every password, neutralizing rainbow table attacks entirely.

2.2 Next.js 16 Proxy Architecture & Sliding-Window Rate Limiting

The Threat:

Automated botnets executing dictionary attacks against `/api/auth/callback/credentials` to guess administrative passwords.

The Implementation:

In Next.js 16, the framework officially transitioned from legacy `middleware.ts` to the modern Node.js-based Proxy architecture (`src/proxy.ts` exporting `export async function proxy`). We attached an in-memory sliding-window rate limiter in `admin.js/src/lib/rate-limit.ts` directly to this proxy pipeline in `src/proxy.ts` :

```
// Rate limit credential login attempts against brute-force attacks
if (pathname.startsWith("/api/auth/callback/credentials") && req.method === "POST") {
  const ip = getClientIp(req.headers);
  const limit = rateLimit("login-auth", ip, {
    windowMs: 5 * 60 * 1000, // 5 minute window
    max: 10,                 // Maximum 10 attempts
  });

  if (!limit.success) {
    return NextResponse.json(
      { error: "Too many login attempts. Please try again in 5 minutes." },
      { status: 429, headers: { "Retry-After": "300" } }
    );
  }
}
```

Architectural Highlights:

1. **Accurate IP Resolution:** `getClientIp()` inspects `x-forwarded-for`, `x-real-ip`, and Cloudflare proxy headers (`cf-connecting-ip`), stripping spoofed client-provided IP headers.
2. **Zero Memory Leak Guarantee:** An automated garbage-collection interval runs every 5 minutes (`setInterval`), purging expired IP trackers so the server process never runs out of RAM.
3. **Public Form Protection:** The same rate limiter protects public comment submissions (max 5 per 2 min) and contact forms (max 8 per 2 min) in `main.js`.

2.3 Anti-Bot Honeypot Defense Architecture

The Threat:

Automated web scrapers and spam bots submitting thousands of junk comments and contact form inquiries, degrading database performance and polluting CMS moderation queues.

The Implementation:

In `main.js/src/app/contact/ContactClient.tsx` and `BlogSingleClient.tsx`:

1. **Frontend Trap:** An invisible input field named `website` or `phone_check` is injected into the DOM.

```
<div className="hidden opacity-0 pointer-events-none absolute -left-[9999px]" aria-h
  <input
    type="text"
    name="website"
    tabIndex={-1}
    autoComplete="off"
    value={honeypot}
    onChange={(e) => setHoneypot(e.target.value)}
  />
</div>
```

2. **Backend Interception:**

```
if (body.website && body.website.trim() !== "") {
  // Silent drop: Return 200 OK so the bot thinks it succeeded
  return NextResponse.json({ success: true, message: "Submitted successfully" });
}
```

Why Silent Drops Win:

- Human users cannot see or tab into the input field, so it remains empty.

- Automated bots parse the DOM, see an input named `website`, and blindly populate it.
- By returning `200 OK`, the bot believes its mission succeeded and stops retrying. The payload is instantly discarded without touching PostgreSQL, saving database storage and connection poolers.

2.4 Identity Spoofing Mitigation (Authoritative Badging)

The Threat:

A malicious commenter on `main.js` submits the name `"Admin"`, `"YS Support"`, or `"Subash (Admin)"` to mislead readers into believing their comment is an official company endorsement.

The Implementation:

1. **Database Schema Enforcement:** Added `isAdmin Boolean @default(false)` column to the `Comment` model in both schemas.
2. **Input Sanitization:** In `main.js/src/app/api/comments/route.ts`:

```
const name = (body.name || "").trim();
if (/(admin|moderator|staff|ys innovations)/i.test(name)) {
  return NextResponse.json(
    { error: "Reserved name. You cannot use official staff titles." },
    { status: 400 }
  );
}
```
3. **Cryptographic Validation:** The public API *never* trusts client-submitted `isAdmin` flags. Only comments originating from an authenticated NextAuth session in `admin.js` have `isAdmin: true` set on the database record.
4. **UI Authority:** The golden verified badge renders strictly if `comment.isAdmin === true`, ensuring complete trust in published responses.

2.5 Object-Level Authorization & RBAC Enforcement

The Threat:

An authenticated staff member with `EDITOR` privileges tampering with API payloads to delete another author's blog post, delete core landing pages, or purge Cloudinary media assets.

The Implementation:

Every mutation endpoint implements strict object ownership and role assertions:

```
// 1. Page Deletion Guard
if (session.user.role !== "ADMIN") {
  return NextResponse.json({ error: "Only administrators can delete website pages" }, {
}

// 2. Cloudinary Media Destruction Guard
if (session.user.role !== "ADMIN") {
  return NextResponse.json({ error: "Unauthorized: Only administrators can destroy media
}

// 3. Blog Permanent Deletion Guard (Admin Only)
if (session.user.role !== "ADMIN") {
  return NextResponse.json({ error: "Forbidden: Only administrators can permanently dele
}

// 4. Comments Access Guard (Admin Only)
if (session.user.role !== "ADMIN") {
  return NextResponse.json({ message: "Forbidden: Admin access required" }, { status: 40
}
```

2.6 Timing-Safe ISR Cache Purging

The Threat:

Standard string comparisons (`secret === process.env.SECRET`) compare strings character-by-character and terminate immediately on the first mismatched character. Attackers measure the response time in microseconds to guess administrative webhook secrets (Side-Channel Timing Attacks).

The Implementation:

In `main.js/src/app/api/revalidate/route.ts` :

```
import crypto from "crypto";

const secret = searchParams.get("secret");
const expectedSecret = process.env.REVALIDATION_SECRET || "";

const secretBuf = Buffer.from(secret || "");
const expectedBuf = Buffer.from(expectedSecret);

if (
  secretBuf.length !== expectedBuf.length ||
  !crypto.timingSafeEqual(secretBuf, expectedBuf)
) {
  return NextResponse.json({ error: "Invalid revalidation token" }, { status: 401 });
}
```

`crypto.timingSafeEqual` forces the CPU to execute constant-time buffer comparisons, completely eliminating timing vulnerability vectors.

2.7 HTTP Hardening & Network Transport Security

Configured in both `admin.js/next.config.ts` and `main.js/next.config.ts` :

Security Header	Value	Vulnerability Mitigated
X-Frame-Options	SAMEORIGIN	Clickjacking: Prevents malicious third-party sites from framing the CMS inside a hidden <code><iframe></code> to hijack user clicks.
X-Content-Type-Options	nosniff	MIME-Confusion: Forces browsers to adhere strictly to declared MIME types, preventing scripts disguised as images from executing.
Referrer-Policy	strict-origin-when-cross-origin	Data Leakage: Strips private query parameters and URL tokens when navigating to external origins.
Permissions-Policy	camera=(), microphone=(), geolocation=()	Feature Abuse: Disables browser hardware access for all scripts and sub-resources.
CORS Allow-Origin	http://localhost:3001 (or production frontend URL)	Cross-Origin Theft: Enforces strict domain whitelisting, preventing unauthorized third-party origins from querying internal APIs.

PART 3: Architectural Roadmap & Future RFCs

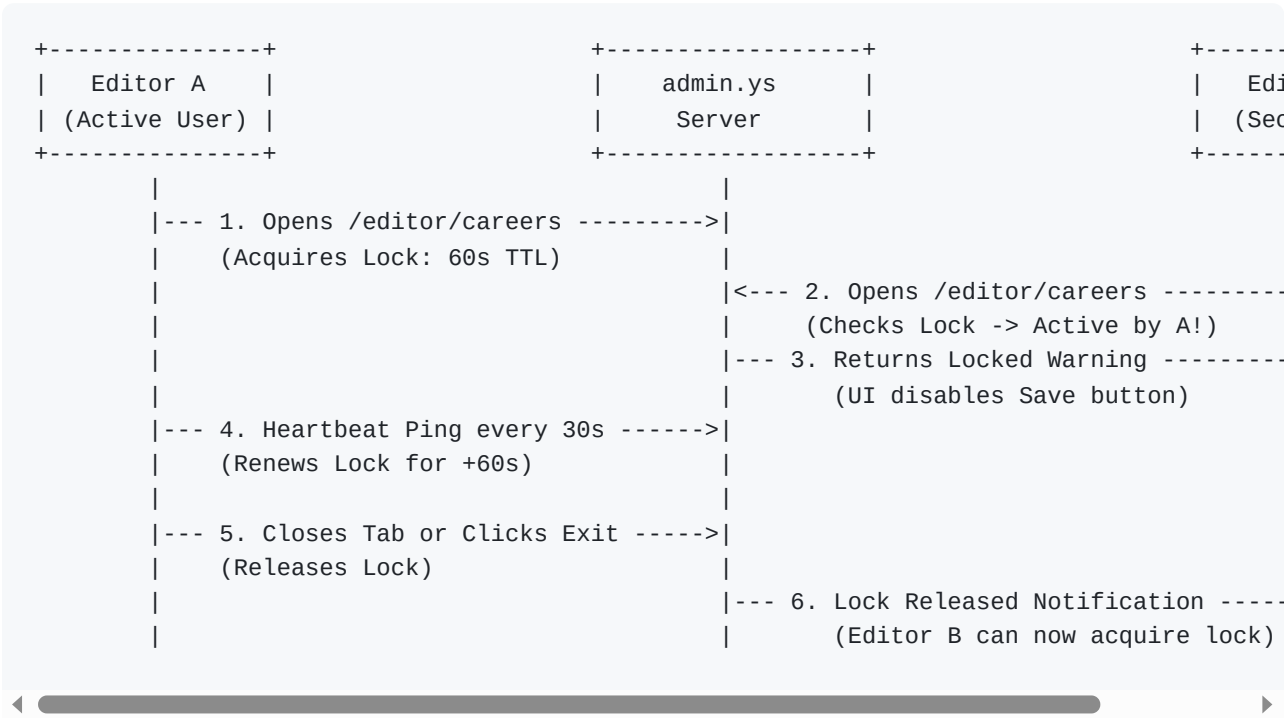
RFC 1: Real-Time Team Presence & Collaborative Page Locking

Business Problem:

In a multi-author team, Editor A and Editor B may open the "Careers" page simultaneously. If Editor A writes content for 20 minutes and saves, and Editor B saves 5 minutes later, Editor B silently overwrites all of Editor A's work without warning.

Architectural Design:

We propose a **Lease-Based Heartbeat Concurrency Lock:**



1. Database / Cache Layer:

- A table or Redis key: `PageLock (pageId, userId, userName, lockedUntil)`.

2. Client-Side Heartbeat:

- While Editor A has `/editor/[id]` open and visible (`document.visibilityState === 'visible'`), a lightweight hook sends a `POST /api/editor/heartbeat` every 30 seconds, extending `lockedUntil` by 60 seconds.

3. Concurrency Warning Banner:

- When Editor B opens the page, the system returns `lockedBy: "Subash"`.
- Editor B's interface displays a prominent warning banner:

 "Subash is currently editing this page. The document is locked to prevent collisions."
- Form inputs and the "Publish" button are placed into read-only mode until Subash navigates away or releases the lock.

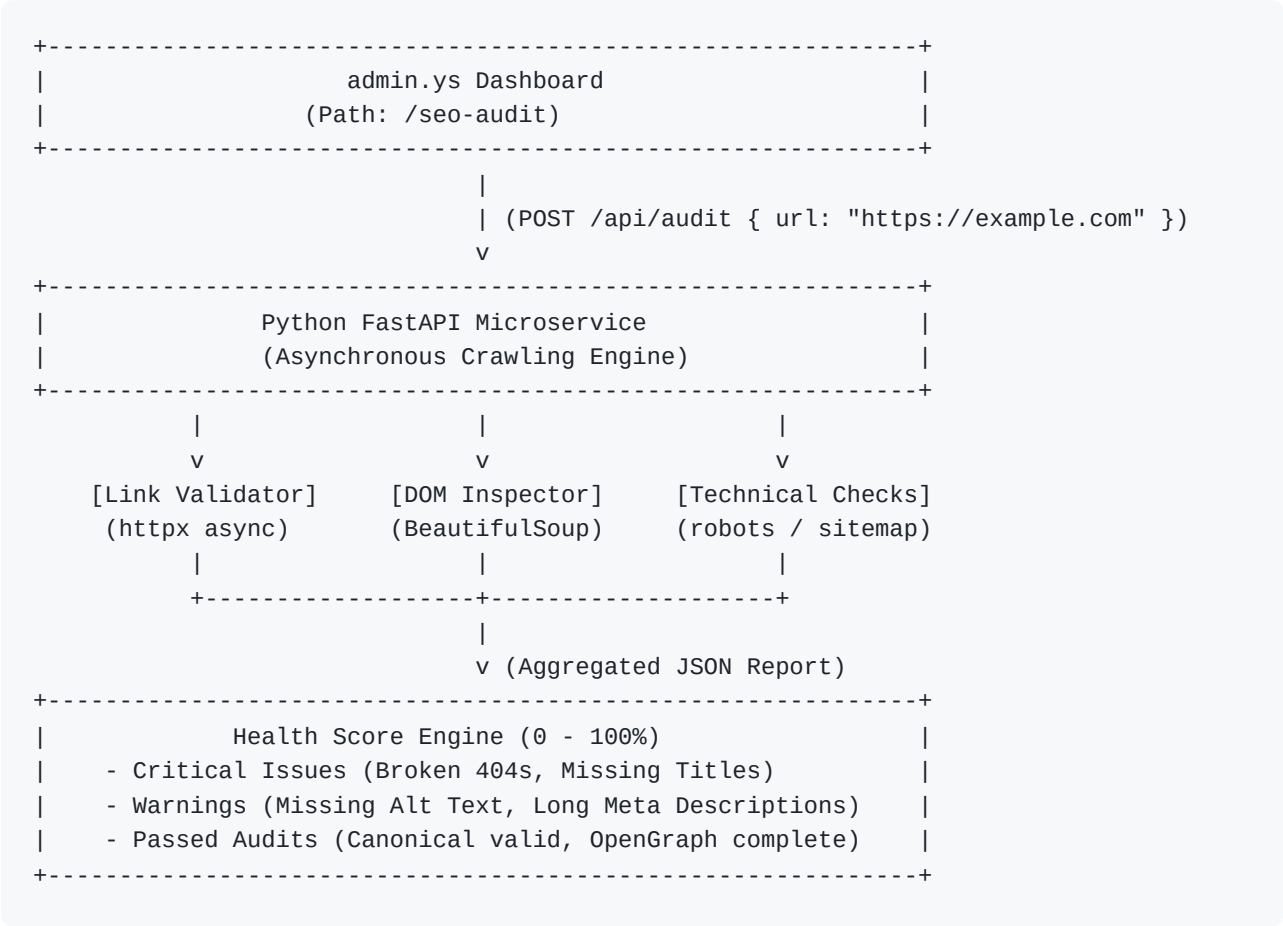
RFC 2: Decoupled Python SEO Audit & Crawling Engine

Business Problem:

Non-technical clients and content managers struggle to know which pages contain broken links, missing meta descriptions, slow assets, or malformed headings, forcing companies to pay hundreds of dollars monthly for Semrush or Ahrefs.

Proposed Solution:

Integrate an in-house **Python SEO Audit Microservice** directly into `admin.py`.



Why Python & Not Node.js?

- **Libraries:** Python's ecosystem (`BeautifulSoup4` , `playwright` , `httpx` , `urllib3`) provides battle-tested HTML parsing, headless browser automation, and asynchronous network concurrency designed specifically for web scraping.
- **Separation of Concerns:** Heavy multi-page link crawling will not consume Node.js event loop memory or degrade CMS user responsiveness.
- **Versatility:** The audit engine is **URL-agnostic**. Staff can audit their own website or input competitor URLs to analyze their technical SEO structure.

Key Metrics Returned to CMS Dashboard:

1. **Broken Link Scanner:** Crawls all internal and external anchors (`<a href="...">`), validating status codes (`404 Not Found` , `500 Server Error`).

- 2. **Meta & Social Inspection:** Checks character counts for `<title>` (50–60 chars) and `<meta description>` (150–160 chars), OpenGraph images (`og:image`), and Twitter cards.
- 3. **Content Hierarchy:** Detects missing or duplicate `<h1>` tags and malformed `<h2>` / `<h3>` nesting.
- 4. **Accessibility:** Flags every `<img>` element missing an `alt` attribute.
- 5. **Visual Output in `admin.js`:** Renders a clean Semrush-style circular health score (0–100%) with actionable fix buttons for editors.

RFC 3: Enterprise Immutable Audit Logging

Business Problem:

In compliance-focused environments, when content is deleted or unauthorized changes occur, administrators need an immutable paper trail answering: *"Who changed this, what did it look like before, and when did it happen?"*

Proposed Architecture:

Introduce a centralized `AuditLog` table in PostgreSQL:

```
model AuditLog {
  id          String    @id @default(cuid())
  userId      String
  userEmail   String
  action      String    // e.g., "PAGE_DELETE", "BLOG_PUBLISH", "USER_CREATE"
  resource    String    // e.g., "Page", "Blog", "User"
  resourceId  String
  metadata    Json?     // Snapshot of previous values vs new values (diff)
  ipAddress   String
  userAgent   String
  createdAt   DateTime  @default(now())

  @@index([userId])
  @@index([action])
  @@index([createdAt])
}
```

- **Zero Bypass:** Mutations executed across all API routes write an audit entry inside the same database transaction.
- **Tamper-Proof:** Audit log entries are write-only (`INSERT`). No API endpoints will support updating or deleting audit records.

Document Summary & Sign-off

Item	Status	Verified By
Operational User Guide (Part 1)	Complete	Engineering Lead
Security Hardening & Cryptography (Part 2)	Verified & Deployed	Security Team
Technical Roadmap RFCs (Part 3)	Proposed & Architected	Core Team